Laboratory #6

Lab #6: Define a Remote Access Policy to Support Remote Healthcare Clinics

Learning Objectives and Outcomes

Upon completing this lab, students will be able to complete the following tasks:

- Define the scope of an remote access policy as it relates to the Remote Access Domain
- Identify the key elements of a remote access policy within an organization as part of an overall security management framework
- Align the remote access policy with the organization's goals for compliance
- Mitigate common risks and threats found within the Remote Access Domain with proper security controls and countermeasures as defined in the remote access policy definition
- Create a remote access policy definition incorporating a policy statement, standards, procedures, and guidelines

Required Setup and Tools

This is a paper-based lab. Internet access and the student's Microsoft Office applications are needed to perform this lab.

The following summarizes the setup, configuration, and equipment needed to perform Lab #6:

1. Standard onsite student workstation must have the following software applications loaded and Internet access to perform this lab:
    a. Microsoft Office 2007 or higher
    b. Adobe PDF reader
    c. Internet access

Recommended Procedures

Lab #6 – Student Steps

1. Review with the instructor sample Remote Access Policy documents found on the Internet:

    SANS Institute: Remote Access Policy Template

    http://www.sans.org/security-resources/policies/Remote_Access_Policy.pdf

    Higher-Education: Clark University

    http://www.clarku.edu/offices/its/policies/remoteaccess.cfm

Copyright © 2013 by Jones & Bartlett Learning, LLC, an Ascend Learning Company
www.jblearning.com All Rights Reserved.

Higher-Education: Purdue University
http://www.purdue.edu/policies/pages/information_technology/v_1_6.shtml

Healthcare: UNC School of Medicine & Healthcare Clinic
http://www.med.unc.edu/security/hipaa/documents/SOM%20Remote%20Access%20Policy%202009%20Final.pdf

2. Discuss what the risks and threats are within the Remote Access Domain per the bulleted list provided:
   - Brute force user ID and password attacks
   - Users or employees unaware of the risks, threats, and dangers of the Internet and shared Wi-Fi or broadband Internet access
   - Multiple access attempts and login retries
   - Unauthorized access to IT systems, applications, and data
   - Privacy data or confidential data is compromised remotely
   - Data leakage occurs in violation of Data Classification Standard
   - Remote worker's laptop is stolen
   - Remote worker's token device is stolen
   - Remote worker requires access to patient medical records system through public Internet
3. Discuss what organizations can do to mitigate the risks and threats identified within the Remote Access Domain
4. Complete the Lab #6 – Assessment Worksheet deliverables: Identify Elements of a Remote Access Policy Definition, Create a Remote Access Policy Definition for Multiple Healthcare Clinics
5. Complete the Lab #6 – Assessment Questions & Answers and submit with this lab.

Deliverables

Upon completion of the Lab #6: Define a Remote Access Policy to Support Remote Healthcare Clinics, the students are required to provide the following deliverables:

1. Lab #6 – Assessment Worksheet: Identify Elements of a Remote Access Policy Definition
2. Lab #6 – Assessment Worksheet: Create a Remote Access Policy Definition for Multiple Remote Healthcare Clinics
3. Lab #6 – Assessment Questions & Answers

Copyright © 2013 by Jones & Bartlett Learning, LLC, an Ascend Learning Company
www.jblearning.com All Rights Reserved.

Evaluation Criteria and Rubrics

The following are the evaluation criteria and rubrics for Lab #6 that the students must demonstrate:

1. Was the student able to define the scope of a remote access policy as it relates to the Remote Access Domain? – [**20%**]
2. Was the student able to identify the key elements of remote access policy within an organization as part of an overall security management framework? – [**20%**]
3. Was the student able to align the remote access policy with the organization's goals for compliance? – [**20%**]
4. Was the student able to mitigate common risks and threats found within the Remote Access Domain with proper security controls and countermeasures as defined in the remote access policy definition? - [**20%**]
5. Was the student able to create a remote access policy definition incorporating a policy statement, standards, procedures, and guidelines? – [**20%**]

Copyright © 2013 by Jones & Bartlett Learning, LLC, an Ascend Learning Company
www.jblearning.com All Rights Reserved.

Lab #6 – Assessment Worksheet

Elements of a Remote Access Domain Policy

Course Name:	**Policy Development in Information Assurance(IAP301)**
Student Name:	**Phạm Hoàng Hải Nguyên-SE180511**
	Nguyễn Trúc Quỳnh- SE180280
	Giả Thị Nhã Trân- SE180405
Instructor Name	**HaiH5**
Lab Due Date	**06/02/2026**

Overview

For each of the identified risks and threats within the Remote Access Domain, identify a security control or security countermeasure that can help mitigate the risk or threat. These security controls or security countermeasures will become the basis of the scope of the Remote Access Domain Policy definition to help mitigate the risks and threats commonly found within the Remote Access Domain.

Remote Access Domain Risks & Threats	Risk Mitigation Tactic / Solution	Technical Implementation	Compliance Alignment	Monitoring & Response
Brute force user ID and password attacks	• Account lockout after multiple failed attempts • Mandatory multi-factor authentication (MFA) • Strong password policy and rate limiting	• Conditional access policies • MFA (OTP / hardware key) • Login rate limiting & CAPTCHA	• HIPAA §164.312(d) • NIST SP 800-63B • ISO 27001 A.9	• Alerts on failed login attempts • SIEM log correlation • Automated IP blocking
Multiple login retries and access control attacks	• Session limits and inactivity timeouts • Privileged access controls • Network segmentation	• Access management platform • Session timeout enforcement • PAM for admin accounts	• HIPAA §164.312(a)(1) • NIST SP 800-53 (AC controls)	• Monitor concurrent sessions • Quarterly access reviews • Auto-disable inactive accounts
Unauthorized remote access to IT systems, applications, and data	• Principle of Least Privilege (RBAC) • Zero Trust access model • Formal access approval process	• Role-based access control • Device compliance checks • Time-limited access provisioning	• HIPAA §164.308(a)(4) • NIST CSF PR.AC • ISO 27001 A.9	• Real-time access monitoring • Unauthorized access alerts • Incident response procedures
Privacy or confidential data compromised remotely	• Encryption for data in transit and at rest • Data Loss Prevention (DLP) • Secure file transfer methods	• TLS encryption • Endpoint and cloud DLP • Secure email / SFTP	• HIPAA §164.312(e) • HIPAA §164.312(a)(2)(iv) • GDPR Article 32	• Alerts on data exfiltration • Forensic analysis • Breach notification process
Data leakage violating Data Classification Standards	• Data classification and labeling • Access control by data sensitivity • User awareness training	• Automated classification tools • Sensitivity labels • Restricted access rules	• HIPAA §164.306(a) • NIST SP 800-53 • ISO 27001 A.8	• Monitor abnormal data movement • Classification compliance reports • Periodic data audits

Remote Access Domain Risks & Threats	Risk Mitigation Tactic / Solution	Technical Implementation	Compliance Alignment	Monitoring & Response
Mobile worker laptop is stolen	• Full Disk Encryption (BitLocker/FileVault, AES-256) • Remote wipe via MDM • Basic physical security (cable lock, privacy screen)	• Pre-boot authentication • TPM-based key storage • Secure Boot enabled	• HIPAA §164.312(a)(2)(iv) • NIST SP 800-111	• Immediate loss reporting • Device access log review • Breach notification per HIPAA
Mobile worker token or other lost or stolen authentication device	• Immediate token revocation • Multi-factor authentication (token + app) • Centralized token management	• RADIUS/TOTP authentication • FIDO2/WebAuthn support	• HIPAA §164.312(d) • NIST SP 800-63B	• Real-time misuse alerts • Session termination • Incident documentation
Remote worker requires access to medical systems through the public Internet	• SSL/TLS VPN access only • Role-based access control • Zero Trust principles	• TLS 1.3 VPN • Conditional access policies • Web Application Firewall	• HIPAA §164.312(e)(1) • NIST CSF	• VPN session logging • Anomaly detection • Periodic security testing
Users and employees are unaware of public Internet risks	• Mandatory security awareness training • Annual refresher courses • Phishing awareness program	• LMS-based training platform • Simulated phishing emails	• HIPAA §164.308(a)(5) • NIST SP 800-50	• Training completion tracking • Phishing click-rate metrics • Incident trend monitoring

Lab #6 – Assessment Worksheet

Define a Remote Access Policy to Support Remote Healthcare Clinics

Course Name:	**Policy Development in Information Assurance(IAP301)**
Student Name:	**Phạm Hoàng Hải Nguyên-SE180511**
	Nguyễn Trúc Quỳnh- SE180280
	Giả Thị Nhã Trân- SE180405
Instructor Name	**HaiH5**
Lab Due Date	**06/02/2026**

Overview

In this lab, you are to create an organization-wide Remote Access Policy for a mock organization under a recent compliance law. Here is your scenario:

- Regional ABC Healthcare Provider with multiple remote, healthcare branches and locations throughout the region
- Online access to patients' medical records through the public Internet is required for remote nurses and hospices providing in-home medical services
- Online access to patients' medical records from remote clinics is done through SSL VPN secure web application front-end through the public Internet
- The organization wants to be in compliance with HIPAA and IT security best practices regarding remote access through the public Internet in the Remote Access Domain

- The organization wants to monitor and control the use of remote access by implementing system logging and VPN connections
- The organization wants to implement a security awareness & training policy mandating that all new hires and existing employees obtain remote access security training. Policy definition to include HIPAA and ePHI (electronic personal healthcare information) security requirements and a mandate for annual security awareness training for all remote or mobile employees

Instructions

Using Microsoft Word, create a Remote Access Policy Definition capturing the elements of the policy as defined in the Lab #6 – Assessment Worksheet. Use the following policy template for the creation of your Remote Access Policy definition for a regional healthcare provider with remote medical clinics.

ABC Healthcare Provider

Remote Access Policy for Remote Workers & Medical Clinics

Policy Statement

ABC Healthcare Provider establishes this Remote Access Policy to formally define the rules, controls, and security requirements governing remote access to organizational systems and electronic Protected Health Information (ePHI). Due to the organization's reliance on remote nurses, in-home healthcare providers, and geographically distributed medical clinics, secure access to patient medical records over the public Internet is essential to daily operations.

This policy ensures that all remote access is authorized, encrypted, authenticated, and continuously monitored in order to prevent unauthorized disclosure, alteration, or destruction of sensitive healthcare information. The policy also supports regulatory compliance with the HIPAA Security Rule by enforcing administrative, technical, and procedural safeguards. Failure to comply with this policy may result in disciplinary action, revocation of access privileges, or legal consequences.

References:

- *https://www.hhs.gov/hipaa/for-professionals/security/index.html*
- *https://csrc.nist.gov/publications/detail/sp/800-46/rev-2/final*

Purpose / Objectives

The purpose of this Remote Access Policy is to protect patient medical data and internal information systems when accessed from locations outside of ABC Healthcare Provider's secured facilities. Remote access introduces increased cybersecurity risks due to the use of public networks, personal devices, and geographically dispersed users. This policy aims to reduce those risks while enabling secure and efficient healthcare service delivery.

The objectives of this policy are to:

- Ensure compliance with HIPAA Security Rule requirements related to the confidentiality, integrity, and availability of ePHI.
- Define secure methods for accessing patient medical records through the public Internet.
- Require the use of encrypted communication channels such as SSL VPN for all remote access.

- Establish monitoring and logging controls to track and audit remote access activities.
- Reduce the likelihood of data breaches, unauthorized access, and cyberattacks.
- Mandate security awareness and HIPAA training for all remote and mobile employees on an initial and annual basis.

References:

- *https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html*
- *https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final*

Scope

This policy applies to all individuals who remotely access ABC Healthcare Provider's information systems, including full-time employees, part-time staff, remote nurses, hospice care workers, contractors, vendors, and authorized third-party users. It covers access originating from home offices, remote clinics, mobile devices, and any non-ABC Healthcare facility.

The policy impacts several domains of a typical IT infrastructure. These include the Remote Access Domain, which governs VPN and external connectivity; the User Domain, which involves user identities and authentication; the Workstation Domain, which includes laptops and mobile devices; the LAN and WAN Domains, which handle internal and external network communication; and the System/Application Domain, which hosts electronic medical record systems.

Assets within the scope of this policy include ePHI, patient medical databases, web-based medical applications, SSL VPN systems, authentication servers, organization-issued and approved personal devices, and security monitoring and logging tools.

References:

- *https://csrc.nist.gov/publications/detail/sp/800-46/rev-2/final*
- *https://www.cisecurity.org/controls*

Standards

ABC Healthcare Provider follows established regulatory and industry standards to ensure that remote access is secure and compliant. All data transmitted between remote users and internal systems must be encrypted using strong cryptographic protocols such as SSL/TLS to protect ePHI from interception or unauthorized disclosure.

Remote access must be conducted through organization-approved SSL VPN solutions that meet internal configuration and security standards. Multi-Factor Authentication (MFA) is required to verify user identity and reduce the risk of credential compromise. VPN systems must be configured according to secure baseline standards, and weak encryption or deprecated protocols are strictly prohibited.

These standards align with HIPAA technical safeguards and NIST recommendations for secure remote access environments and identity management.

References:

- *https://www.hhs.gov/hipaa/for-professionals/security/index.html*
- *https://pages.nist.gov/800-63-3/sp800-63b.html*
- *https://csrc.nist.gov/publications/detail/sp/800-46/rev-2/final*

Procedures

To implement this policy organization-wide, ABC Healthcare Provider will require all remote users to establish a secure SSL VPN connection before accessing any internal systems or patient medical records. Access permissions will be granted based on job role and the principle of least privilege to limit unnecessary exposure to sensitive data.

All remote access activity will be logged, including user authentication attempts, session duration, IP addresses, and accessed systems. Logs will be reviewed regularly by IT security personnel to detect suspicious behavior and support incident response investigations. Unauthorized access attempts will be immediately investigated and may result in account suspension.

Security awareness and training are critical components of this policy. All new hires must complete HIPAA and remote access security training prior to receiving access credentials. Existing employees are required to complete annual security awareness training that covers ePHI protection, secure remote work practices, password management, phishing awareness, and incident reporting procedures.

References:

- *https://www.hhs.gov/hipaa/for-professionals/security/guidance/index.html*
- *https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final*

Guidelines

Implementing secure remote access across multiple locations may present challenges such as limited technical expertise at remote clinics, inconsistent Internet connectivity, and user resistance to security controls. These issues must be proactively addressed to ensure effective policy enforcement.

ABC Healthcare Provider will provide technical documentation, user support, and training resources to assist remote users with VPN configuration and secure access practices. Compliance with this policy will be enforced through access controls, audits, and disciplinary measures when necessary.

This policy will be reviewed and updated periodically to reflect changes in technology, emerging cyber threats, and updates to regulatory requirements. Continuous improvement of remote access security controls is essential to protecting patient data and maintaining regulatory compliance.

References:

- *https://csrc.nist.gov/publications/detail/sp/800-46/rev-2/final*
- *https://www.cisecurity.org/controls*

Note: Your policy document must be no more than 3 pages long.

Lab #6 – Assessment Worksheet

Define a Remote Access Policy to Support Remote Healthcare Clinics

Course Name:	**Policy Development in Information Assurance(IAP301)**
Student Name:	**Phạm Hoàng Hải Nguyên-SE180511**
	Nguyễn Trúc Quỳnh- SE180280
	Giả Thị Nhã Trân- SE180405
Instructor Name	**HaiH5**
Lab Due Date	**06/02/2026**

Overview

This lab presents the risks and threats commonly found in the Remote Access Domain and how the use of the public Internet introduces new challenges regarding security and compliance for organizations. The students created a Remote Access Policy definition specific to a healthcare organization requiring remote access to patients' medical records systems from remote clinics and patient homes from mobile nurses and healthcare providers in the field.

Lab Assessment Questions & Answers

1. What are the biggest risks when using the public Internet as a WAN or transport for remote access to your organization's IT infrastructure?

Answer:

Using the public Internet as a transport medium for remote access introduces significant security risks because the organization does not control the underlying network infrastructure. Data transmitted over the public Internet can be intercepted by attackers through techniques such as packet sniffing, man-in-the-middle attacks, and session hijacking, especially when users connect via public or unsecured Wi-Fi networks. In a healthcare environment, this risk is amplified because the data being transmitted often includes sensitive ePHI, which is highly valuable to cybercriminals.

Additionally, the public Internet exposes remote access services to a global threat landscape, including brute force attacks, credential stuffing, and exploitation of unpatched VPN gateways. Without strong encryption, authentication, and monitoring controls, attackers can gain unauthorized access to internal systems, potentially leading to data breaches, ransomware attacks, service disruptions, and severe regulatory penalties under HIPAA.

References:

- *https://www.hipaajournal.com/hph-sector-warned-about-remote-access-software-risks/*
- *https://www.simbo.ai/blog/the-challenges-of-maintaining-hipaa-compliance-in-a-remote-work-environment-key-strategies-and-considerations-2324378/*

---

2. Why does this mock healthcare organization need to define a Remote Access Policy to properly implement remote access through the public Internet?

Answer:

A Remote Access Policy is required to formally define how remote access is authorized, secured, monitored, and maintained across the organization. In a healthcare setting, where employees such as nurses, doctors, and remote clinics must access patient medical records over the public Internet, the absence of a clear policy can lead to inconsistent security practices, unmanaged access privileges, and increased risk of data exposure.

The policy ensures alignment with HIPAA Security Rule requirements by mandating encryption, authentication controls, audit logging, and role-based access. It also provides governance by clearly defining responsibilities for users, IT administrators, and management. Without this policy, the organization would struggle to demonstrate compliance during audits and would face higher operational and legal risks following a security incident.

References:

- https://www.hipaajournal.com/what-is-hipaa-compliance/
- https://iso-docs.com/blogs/iso-27001-isms/remote-access-policy

---

3. What is the relationship between an Acceptable Use Policy (AUP) and a Security Awareness & Training Policy?

Answer:

The Acceptable Use Policy (AUP) establishes the rules governing how employees may use organizational IT resources, including remote access systems, laptops, VPNs, and Internet connections. It defines acceptable behavior, prohibited actions, and consequences for misuse, forming the baseline for user accountability and compliance.

The Security Awareness & Training Policy complements the AUP by educating users on *why* these rules exist and *how* to comply with them securely. Training programs teach employees about cyber threats, safe remote access practices, phishing attacks, and data protection responsibilities. Together, these policies address both behavioral expectations and user competence, significantly reducing human-related security incidents.

References:

- *https://www.sans.org/information-security-policy/*
- *https://www.simbo.ai/blog/ensuring-hipaa-compliance-while-working-remotely-key-considerations-and-best-practices-3016715/*

---

4. Which type of secure remote VPN solution is recommended for mobile nurses and remote clinics?

Answer:

An SSL VPN solution is the most appropriate secure remote access technology for mobile nurses and remote healthcare clinics because it provides encrypted communication over the public Internet using standard web protocols. SSL VPNs allow users to securely access web-based medical record systems through a browser without requiring complex network configurations, making them ideal for mobile and distributed healthcare workers.

When combined with multi-factor authentication and endpoint security checks, SSL VPNs ensure confidentiality, integrity, and availability of patient data. This approach aligns with HIPAA requirements for encryption in transit and supports scalability for organizations with multiple remote clinics and mobile staff.

References:

- *https://medicalitg.com/healthcare-it-services/best-practices-for-secure-remote-access-for-healthcare-staff/*
- *https://www.cloudflare.com/learning/access-management/what-is-an-ssl-vpn/*

---

5. What is needed within the LAN-to-WAN Domain to monitor and alarm on unauthorized login attempts?

Answer:

Within the LAN-to-WAN Domain, organizations must deploy centralized monitoring and logging solutions such as SIEM systems, intrusion detection systems (IDS), and firewall logging mechanisms. These technologies collect authentication logs from VPN gateways, firewalls, and remote access servers, enabling real-time analysis of login behavior.

By correlating multiple failed login attempts, unusual access times, or suspicious IP addresses, the system can automatically generate alerts for potential brute force attacks or unauthorized access attempts. This proactive monitoring capability is critical for early detection, incident response, and compliance reporting.

References:

- *https://www.ibm.com/topics/siem*
- *https://www.cisa.gov/siem*

---

6. Why is it important to educate mobile workers and users about remote access risks?

Answer:

Mobile workers frequently operate outside the organization's secure perimeter and rely on home networks, hotels, or public Wi-Fi, which are often poorly secured. Without proper education, users may unknowingly expose sensitive credentials, connect to malicious networks, or fall victim to phishing and social engineering attacks.

Educating users increases their ability to identify threats, follow secure connection procedures, and report suspicious activity. In healthcare, this awareness directly protects ePHI and reduces the likelihood of costly breaches caused by human error.

References:

- *https://www.hipaavault.com/resources/hipaa-compliant-remote-work/*
- *https://www.cisa.gov/cybersecurity-awareness-month*

---

7. Why should social engineering be included in security awareness training?

Answer:

Social engineering attacks target human psychology rather than technical vulnerabilities, making them highly effective against untrained users. Attackers use phishing emails, fake phone calls, and impersonation tactics to steal credentials and gain unauthorized access.

Including social engineering in training helps employees recognize manipulation techniques, verify requests, and avoid divulging sensitive information. This is particularly important in healthcare, where compromised credentials can lead directly to access to patient records.

References:

- *https://www.cisa.gov/social-engineering*
- *https://www.hipaajournal.com/phishing-attacks-healthcare/*

---

8. Which domain supports remote access connectivity besides the Remote Access Domain?

Answer:

The LAN-to-WAN Domain plays a critical role in supporting remote access connectivity by managing traffic flow between internal networks and external users. This domain includes routers, firewalls, VPN concentrators, and network monitoring systems that enforce security policies and protect internal resources. Without proper controls in the LAN-to-WAN Domain, remote access connections would bypass essential security defenses, increasing exposure to attacks.

References:

- *https://blog.techprognosis.com/securing-remote-access-best-practices-risks-and-tools-for-organizations/*
- *https://www.sans.org/security-resources/policies/*

---

9. Where are the implementation instructions defined in a Remote Access Policy definition?

Answer:

Implementation instructions are defined in the **Procedures** section of the Remote Access Policy. This section translates policy requirements into actionable steps, such as how VPN accounts are requested, approved, configured, and monitored.

It also explains how different remote access use cases—such as mobile nurses versus remote clinics—are supported while maintaining consistent security controls across the organization.

References:

- *https://iso-docs.com/blogs/iso-27001-isms/remote-access-policy*

- *https://www.sans.org/information-security-policy/*

---

10. How should batch uploads of ePHI from remote clinics be handled?

Answer:

Batch uploads of ePHI should be conducted over encrypted channels using secure VPN connections or secure file transfer protocols. Authentication, authorization, and logging must be enforced to ensure that only authorized systems can upload data.

This requirement should be addressed in the Remote Access Policy and supported by data handling and encryption standards to maintain HIPAA compliance.

References:

- https://www.hhs.gov/hipaa/for-professionals/security/index.html
- https://www.hipaavault.com/resources/hipaa-data-transfer/

---

11. Why is a remote access policy a best practice for remote employees?

Answer:

A remote access policy provides clarity, consistency, and security for employees working remotely. It defines acceptable behavior, security expectations, and consequences, reducing confusion and security gaps.

This policy also supports regulatory compliance and helps organizations manage risk as remote work becomes more common.

References:

- *https://medicalitg.com/healthcare-it-services/best-practices-for-secure-remote-access-for-healthcare-staff/*
- *https://www.nist.gov/cyberframework*

---

12. Why require a separate VPN remote access authorization form?

Answer:

A separate authorization form ensures that remote access is formally approved, documented, and periodically reviewed. This supports the principle of least privilege and helps organizations track who has access to sensitive systems.

It also provides evidence during audits that access was granted appropriately.

References:

- *https://iso-docs.com/blogs/iso-27001-isms/remote-access-policy*
- *https://www.nist.gov/privacy-framework*

---

13. Why align standards, procedures, and guidelines in a remote access policy?

Answer:

Alignment ensures that security requirements are consistent and enforceable across the organization. Standards define mandatory controls, procedures describe implementation, and guidelines provide flexibility.
This structure reduces ambiguity and strengthens compliance.

References:

- *https://www.sans.org/information-security-policy/*
- *https://www.iso.org/isoiec-27001-information-security.html*

---

14. What security controls, monitoring, and logging should be enabled for remote VPN access?

Answer:

Remote VPN access should implement strong authentication, encryption, endpoint validation, and centralized logging. Continuous monitoring allows detection of anomalies and supports incident response.
These controls are essential for protecting healthcare data and meeting compliance obligations.

References:

- *https://www.cisa.gov/vpn-security*
- *https://medicalitg.com/healthcare-it-services/best-practices-for-secure-remote-access-for-healthcare-staff/*

---

15. Should monitoring and logging be mentioned in a Remote Access Policy?

Answer:

Yes, explicitly stating monitoring and logging practices promotes transparency, compliance, and deterrence. Users are informed that activity is monitored, and the organization can support audits and investigations.
This is considered a security best practice.

References:

- *https://iso-docs.com/blogs/iso-27001-isms/remote-access-policy*
- *https://www.hhs.gov/hipaa/for-professionals/security/index.html*